
GCVE BCP-05-X-03 - Vulnerability Handling and Disclosure Timeline

GCVE.eu



Contents

1	GCVE BCP-05-X-03: Vulnerability Handling and Disclosure Timeline	1
1.1	Abstract	1
1.2	Motivation	2
1.3	Placement	3
1.4	Data Model	3
1.5	Handling and Disclosure Events	4
1.5.1	Event Fields	4
1.5.2	Event Types	5
1.5.3	Actor Values	7
1.6	Regulatory Timeline	7
1.6.1	Regulatory Fields	8
1.6.2	Assessment Values	9
1.7	Regulatory Notification Object	10
1.7.1	Notification Status	10
1.8	European Union Cyber Resilience Act Profile	11
1.8.1	early-warning	11
1.8.2	vulnerability-notification	11
1.8.3	final-report	12
1.8.4	CRA Example	12
1.9	Relationship Between BCP-02 and Regulatory Timelines	14
1.10	Public Disclosure and Corrective Measures	16
1.11	Processing and Validation Requirements	16
1.12	Updates and Corrections	17
1.13	Privacy and Security Considerations	17
1.14	Legal and Regulatory Considerations	18
1.15	Interoperability Considerations	19
1.16	Minimal Example	19
1.17	Example JSON Paths	20
1.18	Relationship to Other GCVE BCPs	20

1 GCVE BCP-05-X-03: Vulnerability Handling and Disclosure Timeline



GCVE.eu

- **Version:** 1.0
- **Status:** Draft
- **Date:** 2026-10-01
- **Authors:** GCVE Working Group
- **BCP Extended ID:** BCP-05
- **BCP ID:** BCP-05-X-03

This guide is distributed and available under [CC-BY-4.0](#).

Copyright (C) 2026 [GCVE Initiative](#).

1.1 Abstract

This document defines an extension to GCVE BCP-05 for representing the handling, coordination, remediation, disclosure, and regulatory notification timeline associated with a vulnerability advisory.

The extension provides a machine-readable representation of significant events during the vulnerability lifecycle, following the principles described in GCVE BCP-02 — Practical Guide to Vulnerability Handling and Disclosure.

It additionally provides an optional mechanism for recording regulatory notification milestones, including timelines associated with the European Union Cyber Resilience Act (CRA), without conflating regulatory notification with coordinated vulnerability disclosure or public publication.

The objective is to improve transparency, interoperability, process analysis, and automation while preserving the distinction between:

- vulnerability discovery and reporting;
- acknowledgement and validation;
- coordinated vulnerability disclosure;
- remediation and availability of corrective measures;
- public advisory publication; and
- regulatory notifications.

1.2 Motivation

GCVE BCP-02 recommends that vulnerability advisories include a discovery and disclosure timeline describing significant events such as when a vulnerability was reported, fixed, and publicly disclosed.

In practice, vulnerability handling contains considerably more useful information than these three dates. A complete process may include:

- initial discovery;
- report submission;
- acknowledgement;
- vulnerability validation;
- identifier allocation;
- coordination with affected parties;
- agreement or modification of an embargo;
- development and testing of remediation;
- availability of a workaround;
- availability of a corrective measure;
- detection of active exploitation;
- public disclosure; and
- regulatory notification.

Recording these events in a structured form enables vulnerability databases, CSIRTs, GNAs, CNAs, vendors, open-source projects, researchers, and CVD platforms to exchange and analyse handling timelines consistently.

Regulatory requirements can introduce additional deadlines that are related to, but distinct from, the CVD process. For example, under the European Union Cyber Resilience Act, a manufacturer becoming aware of an actively exploited vulnerability may be subject to specific notification deadlines.

This extension therefore models operational vulnerability-handling events separately from regulatory notification requirements.

1.3 Placement

The extension **MUST** be placed in the `extensions` object of a GCVE BCP-05 record using the key `bcp-05-x-03`.

Its value **MUST** contain one `x_timeline` object.

```
1 {
2   "x_gcve": [
3     {
4       "vulnId": "GCVE-1-2026-12345",
5       "recordType": "advisory",
6       "extensions": {
7         "bcp-05-x-03": {
8           "x_timeline": {
9             "events": [],
10            "regulatory": []
11          }
12        }
13      }
14    ]
15  }
```

The `regulatory` member is **OPTIONAL**.

1.4 Data Model

The `x_timeline` object contains:

Field	Type	Required	Description
<code>events</code>	array of objects	yes	Chronological vulnerability handling and disclosure events.

Field	Type	Required	Description
<code>regulatory</code>	array of objects	no	Regulatory assessments and notification timelines associated with the vulnerability.

1.5 Handling and Disclosure Events

Each member of `events` represents a significant event in the vulnerability lifecycle.

Example:

```
1 {  
2   "id": "evt-3",  
3   "type": "validated",  
4   "timestamp": "2026-09-10T14:20:00Z",  
5   "actor": "vendor",  
6   "description": "The vulnerability was reproduced and confirmed."  
7 }
```

1.5.1 Event Fields

Field	Type	Required	Description
<code>id</code>	string	yes	Identifier unique within the timeline.
<code>type</code>	string	yes	Type of vulnerability lifecycle event.
<code>timestamp</code>	string	yes	ISO 8601 date or RFC 3339 date-time at which the event occurred.

Field	Type	Required	Description
<code>actor</code>	string	no	Role primarily responsible for or associated with the event.
<code>description</code>	string	no	Human-readable description of the event.
<code>references</code>	array of strings	no	Public references providing supporting information about the event.

When a precise time is known, an RFC 3339 date-time SHOULD be used and UTC (Z) SHOULD be preferred.

When only a calendar date is reliably known, an ISO 8601 full date MAY be used.

1.5.2 Event Types

The following event types are defined:

Event type	Description
<code>discovered</code>	The vulnerability was initially discovered.
<code>reported</code>	The vulnerability was reported to a vendor, maintainer, coordinator, GNA, CNA, or other appropriate party.
<code>received</code>	The vulnerability report was received by the handling organization.
<code>acknowledged</code>	Receipt of the vulnerability report was acknowledged.
<code>triaged</code>	Initial security triage was performed.

Event type	Description
validated	The vulnerability was reproduced, confirmed, or otherwise validated.
rejected	The report was determined not to represent a vulnerability or was otherwise rejected.
identifier-assigned	A GCVE, CVE, or other vulnerability identifier was assigned.
coordination-started	Coordinated vulnerability handling involving one or more parties began.
affected-party-notified	An affected vendor, maintainer, downstream project, or other relevant party was notified.
embargo-agreed	A coordinated disclosure or embargo date was agreed.
embargo-extended	An existing coordinated disclosure deadline was extended.
remediation-started	Development of a corrective or mitigating measure began.
mitigation-available	A workaround or temporary mitigation became available.
fix-developed	A corrective change was developed but was not necessarily publicly available.
fix-available	A security update, patch, corrected release, or other corrective measure became available to users.
exploit-observed	Exploitation of the vulnerability was observed or reliably established.
public -disclosure-planned	A public disclosure date was established.
public -disclosure	Vulnerability information was publicly disclosed.
advisory-published	A vulnerability advisory was published.
advisory-updated	A previously published advisory was materially updated.

Event type	Description
<code>case-closed</code>	The handling or coordination case was considered closed.
<code>other</code>	Another significant lifecycle event not covered by the defined vocabulary.

Event types are intended to describe facts rather than workflow states.

Producers MAY omit events that are unknown or not relevant.

Consumers MUST NOT infer that an omitted event did not occur.

Additional event types MAY be introduced in future revisions of this extension. Consumers MUST ignore event types they do not understand rather than rejecting the complete extension.

1.5.3 Actor Values

The `actor` field MAY use one of the following values:

- `reporter`
- `researcher`
- `vendor`
- `maintainer`
- `coordinator`
- `gna`
- `cna`
- `csirt`
- `regulator`
- `downstream`
- `other`

The role identifies the party associated with the event and does not require the publication of a natural person's identity.

1.6 Regulatory Timeline

The optional `regulatory` array represents regulatory processes associated with the vulnerability.

Regulatory notification is distinct from public vulnerability disclosure.

A notification to a competent authority, national CSIRT, ENISA, or another regulatory recipient **MUST NOT** be represented as a **public-disclosure** event unless the vulnerability information was actually made public.

Each regulatory entry describes one regulatory framework or reporting regime.

Example:

```

1  {
2    "framework": "EU-CRA",
3    "jurisdiction": "EU",
4    "assessment": "applicable",
5    "trigger": "actively-exploited-vulnerability",
6    "awarenessAt": "2026-09-10T10:00:00Z",
7    "notifications": [
8      {
9        "type": "early-warning",
10       "dueAt": "2026-09-11T10:00:00Z",
11       "submittedAt": "2026-09-10T15:42:00Z",
12       "status": "submitted",
13       "channel": "CRA-SRP"
14     },
15     {
16       "type": "vulnerability-notification",
17       "dueAt": "2026-09-13T10:00:00Z",
18       "submittedAt": "2026-09-12T08:30:00Z",
19       "status": "submitted",
20       "channel": "CRA-SRP"
21     },
22     {
23       "type": "final-report",
24       "triggerEvent": "evt-fix-available",
25       "dueAt": "2026-09-30T09:00:00Z",
26       "status": "pending",
27       "channel": "CRA-SRP"
28     }
29   ]
30 }
```

1.6.1 Regulatory Fields

Field	Type	Required	Description
<code>framework</code>	string	yes	Regulatory framework or reporting regime.

Field	Type	Required	Description
<code>jurisdiction</code>	string	no	Jurisdiction associated with the framework.
<code>assessment</code>	string	yes	Publisher's current assessment of whether the reporting framework applies.
<code>trigger</code>	string	no	Event or condition potentially triggering the reporting requirement.
<code>awarenessAt</code>	string	no	Time at which the relevant organization became aware of the condition triggering the obligation.
<code>notifications</code>	array of objects	no	Notifications, reports, or other regulatory milestones.
<code>notes</code>	string	no	Additional non-sensitive context.

1.6.2 Assessment Values

The `assessment` field MUST use one of:

- `not-assessed`
- `not-applicable`
- `potentially-applicable`
- `applicable`

The value expresses the publisher's process assessment and MUST NOT be interpreted by consumers as an authoritative legal determination.

1.7 Regulatory Notification Object

Each regulatory notification MAY contain:

Field	Type	Required	Description
<code>type</code>	string	yes	Type of notification or regulatory milestone.
<code>triggerEvent</code>	string	no	<code>id</code> of an event in <code>events</code> that starts or materially affects the relevant deadline.
<code>dueAt</code>	string	no	Applicable deadline calculated by the producer.
<code>submittedAt</code>	string	no	Actual submission timestamp.
<code>status</code>	string	no	Current processing state.
<code>channel</code>	string	no	Reporting mechanism or platform used.
<code>reference</code>	string	no	Non-sensitive identifier or reference for the submission.
<code>basis</code>	string	no	Human-readable reference to the provision establishing the requirement.
<code>notes</code>	string	no	Additional non-sensitive context.

1.7.1 Notification Status

The `status` field SHOULD use one of:

- `pending`

- `submitted`
- `updated`
- `not-required`
- `withdrawn`

These values describe workflow state only.

A `submitted` value MUST NOT by itself be interpreted as evidence of regulatory compliance.

1.8 European Union Cyber Resilience Act Profile

This extension defines `EU-CRA` as the conventional framework identifier for reporting associated with Regulation (EU) 2024/2847, the Cyber Resilience Act.

For an actively exploited vulnerability, an entry MAY use:

```
1 {  
2   "framework": "EU-CRA",  
3   "jurisdiction": "EU",  
4   "trigger": "actively-exploited-vulnerability"  
5 }
```

When the publisher determines that the relevant CRA reporting requirement applies, `assessment` SHOULD be `applicable`.

The timeline MAY record the manufacturer's awareness time using `awarenessAt`.

For an actively exploited vulnerability, the following notification types are defined:

1.8.1 early-warning

Represents the early warning notification required without undue delay and, where applicable, within 24 hours after the manufacturer becomes aware of the actively exploited vulnerability.

Recommended `basis`:

```
1 Regulation (EU) 2024/2847 Article 14(2)(a)
```

1.8.2 vulnerability-notification

Represents the subsequent vulnerability notification required without undue delay and, where applicable, within 72 hours after awareness, unless the relevant information has already been provided.

Recommended `basis`:

1 Regulation (EU) 2024/2847 Article 14(2)(b)

1.8.3 final-report

Represents the final report associated with an actively exploited vulnerability.

The relevant deadline is based on the availability of a corrective or mitigating measure rather than the original awareness timestamp.

A **final-report** SHOULD therefore use **triggerEvent** to reference the corresponding **fix-available** or **mitigation-available** event when that event is represented in the timeline.

Recommended **basis**:

1 Regulation (EU) 2024/2847 Article 14(2)(c)

For CRA actively exploited vulnerability reporting, the final report is, where applicable, due no later than 14 days after a corrective or mitigating measure becomes available.

1.8.4 CRA Example

```
1 {
2   "x_gcve": [
3     {
4       "vulnId": "GCVE-1-2026-12345",
5       "recordType": "advisory",
6       "extensions": {
7         "bcp-05-x-03": {
8           "x_timeline": {
9             "events": [
10              {
11                "id": "evt-discovery",
12                "type": "discovered",
13                "timestamp": "2026-09-07",
14                "actor": "researcher"
15              },
16              {
17                "id": "evt-report",
18                "type": "reported",
19                "timestamp": "2026-09-08T08:15:00Z",
20                "actor": "researcher"
21              },
22              {
23                "id": "evt-ack",
24                "type": "acknowledged",
25                "timestamp": "2026-09-08T09:02:00Z",
```

```
26         "actor": "vendor"
27     },
28     {
29         "id": "evt-validation",
30         "type": "validated",
31         "timestamp": "2026-09-09T13:30:00Z",
32         "actor": "vendor"
33     },
34     {
35         "id": "evt-exploitation",
36         "type": "exploit-observed",
37         "timestamp": "2026-09-10T10:00:00Z",
38         "actor": "vendor",
39         "description": "Evidence established that the
40                        vulnerability was being actively exploited."
41     },
42     {
43         "id": "evt-mitigation",
44         "type": "mitigation-available",
45         "timestamp": "2026-09-10T17:00:00Z",
46         "actor": "vendor"
47     },
48     {
49         "id": "evt-fix-available",
50         "type": "fix-available",
51         "timestamp": "2026-09-16T09:00:00Z",
52         "actor": "vendor",
53         "description": "Security update made available to users
54                        ."
55     },
56     {
57         "id": "evt-disclosure",
58         "type": "public-disclosure",
59         "timestamp": "2026-09-16T09:15:00Z",
60         "actor": "vendor"
61     },
62     {
63         "id": "evt-advisory",
64         "type": "advisory-published",
65         "timestamp": "2026-09-16T09:15:00Z",
66         "actor": "vendor"
67     }
68 ],
69 "regulatory": [
70     {
71         "framework": "EU-CRA",
72         "jurisdiction": "EU",
73         "assessment": "applicable",
74         "trigger": "actively-exploited-vulnerability",
75         "awarenessAt": "2026-09-10T10:00:00Z",
76         "notifications": [
```

```

75         {
76             "type": "early-warning",
77             "dueAt": "2026-09-11T10:00:00Z",
78             "submittedAt": "2026-09-10T15:42:00Z",
79             "status": "submitted",
80             "channel": "CRA-SRP",
81             "basis": "Regulation (EU) 2024/2847 Article 14(2)(a)"
82         },
83         {
84             "type": "vulnerability-notification",
85             "dueAt": "2026-09-13T10:00:00Z",
86             "submittedAt": "2026-09-12T08:30:00Z",
87             "status": "submitted",
88             "channel": "CRA-SRP",
89             "basis": "Regulation (EU) 2024/2847 Article 14(2)(b)"
90         },
91         {
92             "type": "final-report",
93             "triggerEvent": "evt-fix-available",
94             "dueAt": "2026-09-30T09:00:00Z",
95             "status": "pending",
96             "channel": "CRA-SRP",
97             "basis": "Regulation (EU) 2024/2847 Article 14(2)(c)"
98         }
99     ]
100 }
101 ]
102 }
103 }
104 }
105 }
106 ]
107 }

```

1.9 Relationship Between BCP-02 and Regulatory Timelines

GCVE BCP-02 defines practical recommendations for coordinated vulnerability handling and disclosure.

The events represented by this extension provide a machine-readable expression of that process.

In particular:

```

1 discovered
2 |

```

```

3  reported
4  |
5  received / acknowledged
6  |
7  triaged / validated
8  |
9  coordination-started
10 |
11 remediation-started
12 |
13 mitigation-available / fix-developed
14 |
15 fix-available
16 |
17 public-disclosure / advisory-published
18 |
19 case-closed

```

Individual cases MAY omit steps, contain additional steps, or execute several steps in parallel.

Regulatory processes MAY branch from this timeline independently:

```

1          +--> regulatory awareness
2          |
3  validated/exploit--+          +--> early warning
4          |
5          |          +--> vulnerability notification
6          |
7  fix/mitigation available ----+--> final report

```

The existence of regulatory reporting MUST NOT modify the semantics of CVD events.

In particular:

- a CRA early warning is not a public disclosure;
- a CRA vulnerability notification is not an advisory publication;
- assignment of a GCVE or CVE identifier does not by itself trigger or satisfy a CRA reporting obligation;
- publication of a vulnerability advisory does not by itself satisfy a regulatory reporting requirement; and
- regulatory reporting does not by itself mean vulnerability information has been publicly disclosed.

1.10 Public Disclosure and Corrective Measures

BCP-02 recommends coordinating public disclosure with the availability of a fix or other protective measure whenever practical.

For products within the scope of applicable regulation, additional vulnerability-handling requirements may apply.

The operational timeline SHOULD therefore distinguish at least:

```
1 fix-developed
```

from:

```
1 fix-available
```

and from:

```
1 public-disclosure
```

A fix can exist internally before it is available to users, and the availability of a corrective measure can itself trigger a regulatory deadline.

1.11 Processing and Validation Requirements

1. `events` MUST contain an array of event objects.
2. Every event MUST contain a unique `id`, a `type`, and a `timestamp`.
3. Events SHOULD be ordered chronologically.
4. Producers MUST preserve the factual distinction between report receipt, validation, remediation, availability of a corrective measure, and public disclosure.
5. A `triggerEvent` MUST reference an existing event `id` within the same `x_timeline` object.
6. Regulatory notifications MUST NOT be represented as public disclosure unless the underlying information was actually made public.
7. `dueAt` values SHOULD represent deadlines determined by the producer from the applicable regulatory requirements. Consumers SHOULD NOT independently infer legal compliance solely by comparing `dueAt` and `submittedAt`.
8. Regulatory deadlines MAY depend on facts, exceptions, interpretations, or subsequent regulatory guidance not represented in the vulnerability record.

9. **assessment:** **applicable** indicates the producer's assessment and MUST NOT be interpreted as a definitive legal determination by downstream consumers.
10. Unknown event types, regulatory frameworks, notification types, or fields MUST NOT cause consumers to reject the complete extension.
11. Producers SHOULD include only information that is appropriate for the distribution level of the containing vulnerability record.
12. Producers MUST NOT publish confidential regulatory identifiers, coordination details, personal information, or non-public vulnerability information merely for the purpose of completing the timeline.

1.12 Updates and Corrections

A vulnerability timeline can evolve after publication.

For example:

- active exploitation may be discovered after an advisory has been published;
- additional affected parties may be identified;
- a corrective measure may be replaced;
- regulatory notifications may be updated;
- an embargo may change;
- the advisory may be corrected or expanded.

Producers MAY append additional events to the timeline.

Previously published factual events SHOULD NOT normally be removed. If an event was incorrect, the publisher SHOULD correct it in a way that preserves sufficient provenance to understand the change when supported by the surrounding publication system.

1.13 Privacy and Security Considerations

Vulnerability-handling timelines can reveal sensitive operational information.

In particular, they may disclose:

- when an organization first became aware of a vulnerability;

- the existence of confidential coordination;
- vendors or downstream projects that were privately notified;
- regulatory submissions;
- internal remediation activities;
- embargo periods;
- non-public exploitation information; or
- identifiers issued by regulatory platforms.

A producer **MUST** review timeline data before publication.

The presence of fields such as [description](#), [reference](#), or [notes](#) **MUST NOT** be used to publish confidential information that would otherwise be excluded from the vulnerability advisory.

When this extension is used internally before public disclosure, implementations **MAY** maintain additional non-public events. These **SHOULD** be removed, redacted, or transformed as appropriate before publishing the GCVE record.

The [reference](#) field of a regulatory notification **SHOULD NOT** contain confidential CRA SRP submission identifiers unless their publication has explicitly been determined to be appropriate.

1.14 Legal and Regulatory Considerations

This extension is a vulnerability-information interchange format and not a compliance determination mechanism.

Regulatory deadlines and requirements may change through legislation, delegated acts, implementing acts, regulatory guidance, judicial interpretation, or other applicable rules.

Therefore:

- producers are responsible for determining which regulatory obligations apply;
- consumers **MUST NOT** treat the presence or absence of this extension as evidence of regulatory compliance;
- consumers **MUST NOT** treat timeline calculations as legal advice; and
- regulatory profiles **SHOULD** be revised when the applicable framework changes.

The explicit [dueAt](#) field is preferred over requiring consumers to calculate regulatory deadlines from hard-coded rules. This allows the format to remain useful when regulatory requirements evolve.

1.15 Interoperability Considerations

The timeline is intended to complement rather than replace existing BCP-05 and CVE record fields.

The extension SHOULD NOT duplicate:

- vulnerability descriptions;
- affected product information;
- CVSS metrics;
- CWE classifications;
- references already represented by the containing record; or
- KEV assertions.

Where active exploitation is established, a publisher SHOULD additionally consider publishing the corresponding machine-readable information using GCVE BCP-07.

BCP-05-X-01 MAY be used when AI-assisted processing contributed to the generation or analysis of timeline information.

BCP-05-X-02 MAY be used when vulnerability metadata or remediation information was derived from analysis of a software patch.

1.16 Minimal Example

A producer that only wants to publish the disclosure history MAY use:

```
1 {
2   "bcp-05-x-03": {
3     "x_timeline": {
4       "events": [
5         {
6           "id": "evt-1",
7           "type": "reported",
8           "timestamp": "2026-08-20",
9           "actor": "researcher"
10        },
11        {
12          "id": "evt-2",
13          "type": "acknowledged",
14          "timestamp": "2026-08-20",
15          "actor": "vendor"
16        },
17        {
```

```
18         "id": "evt-3",
19         "type": "validated",
20         "timestamp": "2026-08-22",
21         "actor": "vendor"
22     },
23     {
24         "id": "evt-4",
25         "type": "fix-available",
26         "timestamp": "2026-09-12",
27         "actor": "vendor"
28     },
29     {
30         "id": "evt-5",
31         "type": "advisory-published",
32         "timestamp": "2026-09-12",
33         "actor": "vendor"
34     }
35 ]
36 }
37 }
38 }
```

1.17 Example JSON Paths

The handling events for a vulnerability are located at:

```
1 containers.cna.x_gcve[0].extensions.bcp-05-x-03.x_timeline.events
```

The CRA regulatory timeline is located at:

```
1 containers.cna.x_gcve[0].extensions.bcp-05-x-03.x_timeline.regulatory
```

An individual regulatory notification can therefore be located under:

```
1 containers.cna.x_gcve[0].extensions.bcp-05-x-03.x_timeline.regulatory
  [].notifications[]
```

1.18 Relationship to Other GCVE BCPs

This extension complements:

- **GCVE BCP-02** — defines the practical vulnerability handling and coordinated disclosure process represented by the timeline.

- **GCVE BCP-04** — identifier allocation may be represented using the `identifier-assigned` event.
- **GCVE BCP-05** — defines the containing GCVE vulnerability record.
- **GCVE BCP-05-X-01** — can describe AI assistance used during vulnerability analysis or advisory preparation.
- **GCVE BCP-05-X-02** — can preserve provenance where vulnerability information was generated from software patches.
- **GCVE BCP-07** — should be considered when the timeline establishes known exploitation.
- **GCVE BCP-12** — sightings may provide evidence relevant to an `exploit-observed` event.

The extension is intentionally generic enough to represent non-CRA regulatory or contractual vulnerability-reporting timelines in future implementations.

